Deskwatch

Transparency & Security Report

What Deskwatch does, what it connects to, what data it touches and how it protects you

Version reviewed: 2.9.21 Date: October 28, 2026 Windows 10 and 11

> This document is a **self-assessment**: it was prepared by the project itself by reviewing the application's entire source code, not by an independent security firm. It is published so anyone can know exactly what the program does. If you find something that doesn't add up, let us know and we'll look into it.

At a glance

✓ **No telemetry or analytics**

Deskwatch does not collect usage data, does not send crash reports and has no servers of its own to send anything to.

✓ **Everything stays on your computer**

The internal server only answers your own computer and is protected by a secret key that changes on every launch. A website open in your browser cannot control it.

✓ **It doesn't read your credentials**

It never touches your Claude login. The GitHub token is never stored or logged, and is only used with github.com.

✓ **No administrator rights**

It installs for your user only. It installs no services, doesn't touch the system registry and runs nothing at Windows startup unless you turn it on.

! **Installer without a digital signature**

For now the installer is not signed with a publisher certificate, which is why Windows may show "Unknown publisher". Details in section 8.

1. What Deskwatch is

Deskwatch is a Windows desktop app that shows your **Claude Code** sessions (Anthropic's coding assistant) as characters in a 3D office. From it you can start new sessions, chat with each agent, approve or deny the permissions they ask for, keep an eye on your plan usage and save your projects to GitHub.

Deskwatch is not an AI model and does not replace Claude Code: it uses Anthropic's official tool (the `Claude Agent SDK`, bundled with the installer) with **your own** Claude account. Conversations go from your computer to Anthropic exactly as when you use Claude Code in a terminal.

2. Internet connections

This is the complete list of destinations Deskwatch's code connects to. There are no others.

DESTINATION	PURPOSE	WHEN
Anthropic (via Claude Code)	Conversations with the agents and checking your plan usage.	While you use agents and, with the window open, every few minutes for plan usage.
github.com (downloads)	Checking for new Deskwatch versions.	At launch and every 4 hours. It only downloads if you accept.
github.com (your repositories)	Saving, pushing and pulling changes to your projects; creating repositories; installing skills you choose.	Only when you ask.
YouTube (youtube-nocookie.com, i.ytimg.com)	The office TVs and radios, if you play a video. Searching sends the text you type to YouTube.	Only if you use that feature.

> Discord is not an internet connection made by Deskwatch: the presence talks to the Discord app running on your computer (section 5).

3. What it reads on your computer

- Claude Code conversations (`%USERPROFILE%\.claude\projects`), to show history, resume conversations and calculate usage.
- Claude Code configuration (`%USERPROFILE%\.claude\settings.json`), its skills and plugins.
- The folders of the projects you add, to show their Git status. On first launch it adds as projects the folders where you've used Claude Code in the last 90 days (you can remove them any time).
- If PC music is on: the title, artist and cover of what's playing in Windows (Spotify, the browser…), using Windows' own media features. It never leaves your computer unless you choose to share it on Discord.

4. What it writes on your computer

LOCATION	CONTENTS
`%USERPROFILE%\.claude\despacho\`	Deskwatch data: projects, notes, decoration, settings, daily usage, attachments you send to terminal sessions and the skills recycle bin. Also `server.json`, holding the port and key of the current local server session.
`%APPDATA%\Deskwatch\`	Window settings (system tray, Discord, start with Windows).
`%USERPROFILE%\.claude\settings.json`	Only if you enable it: the hooks from section 5, the reply language and the skills you turn on or off. A backup is saved before any change (`settings.json.bak-deskwatch`).
Your projects	Only when you use GitHub from Deskwatch: a basic `.gitignore` (if there is none) and the commits you choose to save.

5. Optional integrations

Terminal and VS Code sessions (hooks)

If you enable them, Deskwatch adds *hooks* to Claude Code's global configuration. That way it also sees the sessions you open outside the app: each one tells Deskwatch what it's doing (the message you type, the tools it uses and the folder) **only within your computer**, never over the internet. From Deskwatch you can then approve their permissions, send them messages or pause them if you turn on the usage guard.

If Deskwatch is closed, the hooks do nothing. You can remove them with one click in Settings → Integrations.

Discord presence

On by default, it shares only the number of working agents on your Discord profile. The **project name** and the **music** are shared only if you turn them on in Settings (since version 2.9.21). File names and conversation contents are never shared.

Start with Windows

Off by default. Closing the window keeps Deskwatch in the system tray (this can be changed in Settings).

6. Credentials

- **Claude:** Deskwatch neither reads nor stores your Claude credentials. Login is handled by Claude Code; Deskwatch only asks whether you're signed in so it can show you.
- **GitHub:** to push changes it uses the session you already have in the official `gh` tool. The token is passed to Git in memory only and only for github.com: it is never written to disk, to your repository or to any log. Addresses containing a username and password are rejected, and error messages are scrubbed of credentials before being shown.

7. Security measures

AREA	PROTECTION
Local server	Listens only on `127.0.0.1` (your own computer). Requires a random secret key, different on every launch, on every request. Rejects requests with any other host name (prevents DNS rebinding). Does not allow requests from other websites (no CORS).
App window	Isolated (`contextIsolation` , `sandbox` , no Node access). It cannot navigate away from the office; links open in your browser. Every system function checks the call comes from the office itself.
Agent content	Markdown replies are cleaned with DOMPurify before being shown; all other text is escaped. A Content Security Policy (CSP) prevents running any code other than the app's own.
System commands	Git, GitHub CLI, Claude Code and PowerShell run without a command shell and with separate arguments, so a file or branch name cannot inject commands.
Agent permissions	Each agent uses the permission mode you choose (ask, accept edits, auto…). Unknown values are rejected.
Files	The server only serves the app's own files; paths trying to escape that folder are rejected.

8. Findings from this review

Everything that was found, with its status. Fixes are included in version 2.9.21.

FINDING	SEVERITY	STATUS
DOMPurify 3.4.16 library with known vulnerabilities (not exploitable with the way Deskwatch used it)	High	✓ Fixed: updated to 3.4.17. `npm audit` : 0 vulnerabilities.
No Content Security Policy (CSP)	Medium	✓ Fixed: strict CSP, plus `nosniff` , `no-referrer` and anti-framing protection.
Discord shared the project name and music by default	Medium	✓ Fixed: now opt-in (off by default).
An agent's permission mode was not validated	Medium	✓ Fixed: only Claude Code's modes are accepted.
Removing a skill accepted `.claude\skills` folders anywhere	Medium	✓ Fixed: only global skills or those of your projects.
Checks that could be stricter: conversation id, plugin id, file paths, request size, window navigation	Low	✓ Fixed.
A copy of `settings.json` piled up on every hooks change	Low	✓ Fixed: a single copy. Older ones (`settings.json.bak-despacho-*`) can be deleted by hand.

FINDING	SEVERITY	STATUS
The hooks notice did not explain they apply to every session	Low	✓ Fixed: the text now explains it.
Installer and updates without code signing	High	! Pending. Updates are checked against a SHA-512 hash, but that hash comes from the same GitHub page. If someone took over the project's account they could publish a fake version. Signing the installer is planned.
Another program already running as your user can read the local server key and use its API	Medium	! Accepted. This is the same trust level as the rest of your files: a malicious program running as you could already read them or run Claude Code directly.
Third-party skills and plugins are installed from the repositories you choose	Medium	! By design. Deskwatch shows a preview before installing; only install skills from sources you trust, just like in Claude Code.

9. Recommendations for you

- Only download Deskwatch from **deskwatch.es** or **github.com/davidrfyt/deskwatch/releases**.
- Keep the app up to date: it tells you itself when a new version is available.
- Choose each project's permission mode carefully. "Don't ask" mode lets the agent act without asking for permission.
- Only install skills and plugins from sources you trust.

10. Uninstalling completely

- Before uninstalling, if you enabled terminal sessions: Settings → Integrations → **Remove** the hooks.
- Uninstall Deskwatch from Windows Settings → Apps.
- To delete your data as well: the folders `%USERPROFILE%\.claude\despacho` and `%APPDATA%\Deskwatch`, and the `settings.json.bak-*` copies in `%USERPROFILE%\.claude`. Your projects and your Claude Code conversations are left untouched.

11. How this review was done

The entire source code of version 2.9.21 was reviewed (local server, interface, Claude Code integration, Git and GitHub, Electron window, updates and installer), looking for network connections, file access, credential handling, command execution and unfiltered content. Dependencies were checked with `npm audit` and the installer signature with Windows tools. The fixes were verified in operation: malicious paths, invalid values, the Content Security Policy and the app's normal behavior.

This report will be updated when there are relevant changes.

Claude and Claude Code are trademarks of Anthropic. Deskwatch is an independent project and is not affiliated with Anthropic.